

**UNIVERSIDADE ESTADUAL DE CIÊNCIAS DA SAÚDE DE ALAGOAS
PROGRAMA DE EDUCAÇÃO PELO TRABALHO PARA A SAÚDE — PET-SAÚDE
CENTRO DE DIAGNÓSTICO E IMAGEM PROFESSOR ALBERTO CARDOSO —
CEDIM**

JOSÉ ALAN DE AQUINO SANTOS

**AVALIAÇÃO TÉCNICA DO SISTEMA DE ANAMNESES CEDIM:
CAMPOS, SEGURANÇA E PLANO DE TRABALHO**

**MACEIÓ
2026**

JOSÉ ALAN DE AQUINO SANTOS

**AVALIAÇÃO TÉCNICA DO SISTEMA DE ANAMNESES CEDIM:
CAMPOS, SEGURANÇA E PLANO DE TRABALHO**

Relatório técnico apresentado à equipe de desenvolvimento e à orientação do Programa de Educação pelo Trabalho para a Saúde (PET-Saúde) da Universidade Estadual de Ciências da Saúde de Alagoas, como registro da verificação realizada na plataforma de anamneses do CEDIM e como proposta de distribuição de tarefas.

**MACEIÓ
2026**

RESUMO

Este relatório registra a verificação técnica da plataforma de anamneses mamárias do CEDIM, desenvolvida no âmbito do PET-Saúde da UNCISAL. A verificação foi conduzida com a aplicação em execução, de modo que cada defeito relatado corresponde a um comportamento observado, e não a uma suspeita levantada por leitura de código. O documento cumpre três objetivos. Primeiro, descreve os campos que compõem a anamnese, o que cada um representa e em que formato é gravado, suprimindo uma lacuna de documentação do projeto. Segundo, apresenta os vinte e nove pontos de melhoria identificados, dos quais o mais grave anula por completo o controle de acesso: o componente que protege as rotas verifica apenas a presença do identificador de sessão, sem conferir sua autenticidade, de forma que qualquer pessoa lê e grava prontuários sem credencial válida. Terceiro, propõe uma distribuição de tarefas entre os três desenvolvedores e a orientação do projeto, separando o que depende de conhecimento técnico do que depende de conhecimento clínico. Recomenda-se que a plataforma não receba dados de pacientes reais antes da conclusão da primeira etapa do plano apresentado.

Palavras-chave: Registro eletrônico em saúde. Segurança da informação. Controle de acesso. Anamnese mamária. PET-Saúde.

SUMÁRIO

1 INTRODUÇÃO	5
2 METODOLOGIA	6
3 O SISTEMA AVALIADO	7
4 OS CAMPOS DA ANAMNESE	8
4.1 Identificação da paciente	8
4.2 Histórico mamário	9
4.3 História reprodutiva	9
4.4 História familiar e hábitos	10
4.5 Exame físico	10
4.6 Pontos a confirmar com a orientação	11
5 RESULTADOS DA VERIFICAÇÃO	12
5.1 Segurança	12
5.2 Defeitos funcionais	13
5.3 Desempenho e modelo de dados	13
5.4 Documentação e qualidade	13
6 PLANO DE AÇÃO	15
7 DISTRIBUIÇÃO DE TAREFAS	16
7.1 José Alan — Segurança e autenticação	16
7.2 Alan da Silva — Dados e desempenho	16
7.3 Lucas — Interface e qualidade	17
7.4 Professor Gustavo — Definição clínica	17
8 CONSIDERAÇÕES FINAIS	19
REFERÊNCIAS	20

1 INTRODUÇÃO

O Sistema de Anamneses CEDIM é uma plataforma web que substitui o preenchimento em papel da anamnese mamária: a estudante ou profissional preenche um formulário clínico na tela, marca achados sobre um desenho esquemático das mamas e grava o registro, que fica disponível para consulta, exportação em planilha e agregação em gráficos.

Um sistema assim guarda aquilo que a Lei Geral de Proteção de Dados Pessoais define como *dado pessoal sensível* — informação referente à saúde de pessoa identificada (BRASIL, 2018, art. 5º, II) —, submetido a regime de proteção mais estrito que o dos dados comuns. A qualidade técnica da plataforma deixa, portanto, de ser conveniência e passa a ser questão de conformidade legal.

Este relatório registra a verificação realizada em 23 de setembro de 2026. Não pretende criticar o trabalho feito, que resolve o problema proposto e está em funcionamento, mas produzir um retrato do estado atual, documentar os campos da anamnese e propor uma divisão de tarefas para a equipe. Os conceitos técnicos são explicados à medida que aparecem, pois o documento se dirige também à orientação do projeto.

2 METODOLOGIA

A verificação foi conduzida com a aplicação em execução, e não apenas por leitura do código-fonte. A distinção importa: ler o código levanta suspeitas, mas só a execução confirma que o problema acontece. Cada defeito da seção 5 foi reproduzido ao menos uma vez.

O ambiente foi montado de forma isolada, seguindo o procedimento de instalação da própria documentação do projeto — o que permitiu verificar, de passagem, se essas instruções ainda funcionam. Com o sistema no ar, foram exercitados o fluxo de autenticação, as seis rotas de programação (com e sem credenciais), a gravação de registros completos, vazios e repetidos, a remoção de registros existentes e inexistentes, e a medição do volume de dados trafegado. A descrição dos campos da seção 4 foi extraída do código do formulário, única fonte existente sobre o assunto até este trabalho.

3 O SISTEMA AVALIADO

A plataforma usa Next.js, estrutura que reúne num mesmo projeto as telas e a programação de servidor. O armazenamento fica em banco MySQL, acessado pelo Prisma. São quatro telas: formulário de anamnese, listagem de registros, painel de métricas e tela de acesso. Não há autocadastro; um usuário administrador é criado na instalação.

Um ponto da arquitetura explica vários achados adiante. Todo o conteúdo clínico é gravado em uma única coluna do banco, no formato JSON — um texto estruturado. A tabela possui seis colunas, e nenhuma corresponde a um campo clínico: `id`, `data` (o bloco JSON com tudo), três colunas de imagem e a data de gravação.

A consequência é que o banco não sabe o que guarda. Para ele, a anamnese inteira é um texto só. Não há como exigir que toda anamnese tenha nome de paciente, nem como localizar uma paciente sem percorrer todos os registros.

4 OS CAMPOS DA ANAMNESE

Esta seção descreve os campos do formulário: o que cada um representa e em que formato é gravado. Até este trabalho, essa informação existia apenas no código-fonte, o que obrigava cada nova integrante da equipe a redescobri-la por leitura.

Os quadros indicam o nome técnico do campo — o mesmo que aparece nas planilhas exportadas —, o rótulo exibido na tela e o formato gravado. As linhas destacadas em cinza indicam campos cuja definição clínica precisa ser confirmada pela orientação, conforme a seção 4.6.

4.1 Identificação da paciente

Quadro 1 — Campos de identificação

Campo técnico	Rótulo na tela	Formato e observações
nome	Nome	Texto livre
telefone	Telefone	Texto livre, sem máscara nem validação
cidade	Cidade	Texto livre — sem lista fixa, o que gera grafias divergentes nos gráficos
dataNascimento	Data de Nascimento	Data. Base do cálculo de idade no painel de métricas
motivo	Motivo do Exame	Texto livre — alimenta o gráfico de casos clínicos
exame	Data do Exame	Data informada pela usuária
idExamesAnteriores	ID do Paciente	Texto livre. O nome técnico sugere exames anteriores, mas o rótulo diz identificação da paciente

Fonte: elaborado pelo autor a partir de `components/anamnesis-form.jsx`.

4.2 Histórico mamário

Quadro 2 — Campos de histórico mamário

Campo técnico	Rótulo na tela	Formato e observações
aproveitarExames	Realizou exames anteriores	Sim ou não
jaFezMamo	Já fez mamografia ou ultrassonografia	Sim ou não
sintomas	Sintomas apresentados	Três marcações independentes: dor, massa e secreção
corSecrecao	Cor da secreção	Texto livre
especifiqueSintomas	Secreção sai espontânea?	Texto livre. Nome técnico genérico para pergunta específica
jaFezCirurgia	Já fez cirurgia das mamas	Quatro marcações: mastoplastia, prótese, nódulos e câncer
tempoCirurgia	Tempo de cada cirurgia	Texto livre, um por tipo de cirurgia
cancer	Diagnóstico de câncer pessoal	Sim ou não
especificarCancer	Localização do câncer	Texto livre
historiaDoenca	História da doença mamária	Campo de texto longo — o único do formulário

Fonte: elaborado pelo autor.

4.3 História reprodutiva

Quadro 3 — Campos de história reprodutiva

Campo técnico	Rótulo na tela	Formato e observações
numeroGestacoes	Número de gestações	Número, gravado como texto
numeroPartos	Número de partos	Número, gravado como texto
numeroAbortos	Número de abortos	Número, gravado como texto
historiaReprodutiva	Amamentou · Menopausa · Hormônio	Três marcações independentes
dum	DUM (data da última menstruação)	Data. Só aparece quando "Amamentou" está marcado
tempoMenopausa	Tempo de menopausa	Texto livre; exibido apenas se "Menopausa" marcado
tempoHormonio	Tempo com hormônio	Texto livre; exibido apenas se "Hormônio" marcado

Fonte: elaborado pelo autor.

4.4 História familiar e hábitos

Quadro 4 — Campos de história familiar e hábitos

Campo técnico	Rótulo na tela	Formato e observações
<code>alguemComCancer</code>	Alguém com câncer de mama na família	Sim ou não
<code>parentescoCancer</code>	Parentesco	Texto livre; exibido apenas se a resposta for "sim". Não distingue grau de parentesco nem idade ao diagnóstico
<code>habitos</code>	Fuma · Bebe · Exercício físico · Alimentação saudável · Auto-exame	Cinco marcações independentes. Aparecem duas vezes no relatório impresso: como "Hábitos" e como "Fatores de risco" — são os mesmos dados

Fonte: elaborado pelo autor.

4.5 Exame físico

A seção de exame físico combina dois desenhos esquemáticos das mamas, sobre os quais a usuária marca achados com o mouse ou com o dedo, e campos de seleção associados a cada desenho.

Quadro 5 — Campos de exame físico

Campo técnico	Rótulo na tela	Formato e observações
<code>imagemMamaA</code>	Canvas A	Desenho com as marcações, gravado como imagem. A tela não informa o que distingue este desenho do seguinte
<code>exameFisicoA.massa</code>	Massa na mama?	Sim ou não
<code>indicada</code>	Indicada	Paciente, médico ou técnico. O rótulo não explicita o que está sendo indicado
<code>imagemMamaB</code>	Canvas B	Segundo desenho, mesmo formato do anterior
<code>exameFisicoB.alteracaoPele</code>	Alteração na pele?	Coloração vermelha, verruga ou sinais, outros
<code>exameFisicoB.alteracaoMamilo</code>	Alteração do mamilo	Retração, espessamento, erosão, coloração vermelha, outros

Fonte: elaborado pelo autor.

Quando a opção escolhida é "outros", abre-se um campo de texto para descrição livre. As marcações feitas sobre os desenhos são gravadas apenas como imagem: não podem ser reabertas nem ajustadas depois, e seu conteúdo não é pesquisável.

4.6 Pontos a confirmar com a orientação

Os itens a seguir não podem ser resolvidos por análise técnica, pois dependem do protocolo clínico adotado pelo serviço. Constituem a pauta sugerida para a orientação do projeto.

Quadro 6 — Pontos que dependem de definição clínica

Nº	Questão	Situação atual
1	A DUM deve mesmo aparecer apenas quando "Amamentou" está marcado?	É o comportamento atual; a associação não é evidente
2	O que distingue clinicamente o Canvas A do Canvas B?	A tela não informa; os dois são idênticos em função
3	O campo "Indicada" se refere a quem indicou o exame?	Aceita paciente, médico ou técnico, sem explicação na tela
4	Quais campos devem ser obrigatórios?	Nenhum é. O sistema grava anamnese inteiramente vazia
5	O vocabulário de alterações de pele e mamilo está adequado?	Lista fixa; "coloração vermelha" aparece nos dois campos com grafias internas divergentes
6	O parentesco deve registrar grau e idade ao diagnóstico?	Hoje é texto livre, o que impede estratificação de risco familiar
7	"Motivo do exame" e "Cidade" devem ter lista fixa de opções?	São texto livre; grafias divergentes fragmentam os gráficos

Fonte: elaborado pelo autor.

5 RESULTADOS DA VERIFICAÇÃO

Foram identificados vinte e nove pontos de melhoria: quatro de segurança, sete de defeitos funcionais, quatro de desempenho e modelo de dados, sete de documentação e sete de qualidade de código. Esta seção detalha os mais relevantes.

5.1 Segurança

Quando alguém acerta usuário e senha, o servidor emite um *token*: um texto que funciona como crachá digital e fica guardado no navegador. O token é assinado criptograficamente, de modo que qualquer alteração em seu conteúdo invalida a assinatura e denuncia a falsificação.

O sistema emite o crachá corretamente, mas **nunca confere a assinatura**. O componente que protege as rotas verifica apenas se existe algum crachá, sem olhar o que está escrito nele, e as rotas que leem e gravam anamneses não refazem essa verificação. Apresentando-se um crachá de conteúdo arbitrário, sem nenhuma credencial:

```
Cookie: token=isso_nao_e_um_jwt  
GET    /api/anamneses      → 200 (lista todas as anamneses)  
POST   /api/save-anamnese  → 200 (gravou um registro no banco)
```

A senha protege apenas a formalidade de obter um crachá; não protege os dados. A falha corresponde ao primeiro item da classificação da OWASP (2021), *Broken Access Control*, a categoria mais frequente em aplicações web. A correção exige validar a assinatura no componente de proteção e repetir a validação dentro de cada rota, pois esse componente não constitui, sozinho, uma fronteira de segurança.

Há outros três pontos. Uma rota remanescente de versão anterior permite apagar qualquer arquivo do servidor, por não verificar o identificador recebido — confirmado apagando-se um arquivo criado fora do projeto; como é código sem uso, deve ser removida. As mensagens de erro devolvem ao navegador o caminho absoluto das pastas do servidor e sua estrutura interna. E a credencial do usuário administrador está publicada na documentação do repositório.

5.2 Defeitos funcionais

Quadro 7 — Defeitos que afetam o uso diário

Defeito	Efeito observado
Tela de anamnese completa busca os dados no lugar errado	Exibe sempre "Registro não encontrado"
Ausência total de validação	Grava anamnese sem nome de paciente
Resumo e download individual sem acionamento	Não há como ver a anamnese completa na tela
Campo "Sexo" cobrado pelo painel, inexistente no formulário	Coluna sempre vazia na planilha exportada
Não há edição de anamnese	Corrigir um erro de digitação exige apagar e refazer tudo
Marcações dos desenhos não podem ser reabertas	Achados ficam congelados na imagem
Códigos de erro incorretos	Registro inexistente responde como falha do servidor

Fonte: elaborado pelo autor.

5.3 Desempenho e modelo de dados

A tela de listagem exibe apenas nome, data e cidade, mas a rota que a alimenta devolve todos os registros com todos os campos, incluindo as três imagens de cada um. Não há paginação nem seleção de campos. A medição, com um registro contendo as três imagens, resultou em **781 KB armazenados e 800 KB trafegados**. Com 500 anamneses — volume modesto para um serviço de diagnóstico — cada abertura da tela transferiria cerca de 400 MB, e o painel de métricas repetiria o esforço.

A causa está no modelo descrito na seção 3: como nenhum campo clínico é coluna, não há como pedir apenas o nome e a data. Soma-se a isso que a imagem do relatório reproduz um conteúdo já gravado integralmente no bloco JSON — o mesmo dado ocupa espaço duas vezes, e a versão em imagem não pode ser corrigida nem pesquisada. Registre-se, ainda, que o sistema não guarda quem criou ou apagou cada anamnese.

5.4 Documentação e qualidade

A documentação apresentava um problema de natureza distinta. O arquivo de apresentação do projeto declarava:

Sistema Fechado: Todo o acesso (rotas de registros, formulários e métricas) é protegido por Middleware. É necessário estar logado.

A afirmação não corresponde ao comportamento do sistema. O problema não é o erro em si, mas seu efeito: quem lesse a frase concluiria que a proteção estava resolvida e não investigaria adiante. A documentação atuava para impedir a descoberta da falha. A lição é generalizável: documentação que afirma garantias de segurança precisa ser verificada com o mesmo rigor aplicado ao código, porque é lida como prova.

Quanto à qualidade do código, o projeto soma 2.944 linhas próprias e 13 comentários — 0,4%. O arquivo central, com o formulário inteiro, tem 1.004 linhas e nenhum comentário. Para uma equipe que se renova a cada ciclo do PET, isso significa reconstruir o entendimento do zero a cada turma. Permanecem ainda uma tela órfã, uma função de sessenta linhas nunca chamada, arquivos duplicados e uma pasta de 77 MB de compilação incluída no repositório por engano.

6 PLANO DE AÇÃO

Os vinte e nove pontos não têm a mesma urgência. A ordenação a seguir parte do risco envolvido, e não da facilidade de execução.

Quadro 8 — Plano de ação por etapas

Etapa	Ações	Justificativa
1ª Antes de qualquer dado real	Validar a assinatura do token nas rotas; remover a rota vulnerável; deixar de expor mensagens internas de erro; trocar as credenciais publicadas; implantar validação do formulário	Sem estas, o sistema não oferece proteção alguma aos dados que armazena
2ª Estrutural	Restringir os campos devolvidos pela listagem e paginar; promover nome, cidade e datas a colunas próprias; deixar de gravar a imagem do relatório; corrigir a tela de anamnese completa; implementar edição	Determinam se o sistema suporta o volume de um serviço real
3ª Definição clínica	Responder aos sete pontos do Quadro 6; definir campos obrigatórios e listas fixas; registrar autoria dos registros	Dependem de conhecimento que não está no código
4ª Dívida técnica	Remover a pasta de compilação e o código sem uso; restabelecer a verificação automática de qualidade; comentar o arquivo central	Reduzem o custo de toda alteração futura

Fonte: elaborado pelo autor.

Reforça-se a recomendação central: **a plataforma não deve receber dados de pacientes reais antes da conclusão da primeira etapa**, ainda que utilizada apenas em rede interna.

7 DISTRIBUIÇÃO DE TAREFAS

A equipe é formada por José Alan, Alan da Silva e Lucas, sob orientação do Professor Gustavo. A divisão proposta agrupa as tarefas por afinidade técnica, de modo que cada pessoa trabalhe em arquivos distintos e os três possam avançar em paralelo, sem conflito de edição.

7.1 José Alan — Segurança e autenticação

Responsável pela primeira etapa do plano, que é bloqueante para as demais.

Quadro 9 — Tarefas de José Alan

Tarefa	Onde
Validar a assinatura do token no componente de proteção de rotas	<code>middleware.js</code>
Repetir a validação dentro de cada rota que lê ou grava anamneses	<code>app/api/anamneses/</code> , <code>app/api/save-anamnese/</code>
Remover a rota vulnerável, que não é usada por nenhuma tela	<code>app/api/delete-anamnese/</code>
Parar de devolver a mensagem técnica do erro ao navegador	<code>app/api/save-anamnese/</code>
Validar no servidor os campos definidos como obrigatórios pela orientação	rotas de gravação
Corrigir os códigos de erro: registro inexistente e identificador repetido	rotas de anamnese

Fonte: elaborado pelo autor.

7.2 Alan da Silva — Dados e desempenho

Responsável pela segunda etapa. Trabalha na camada de banco e nas rotas de leitura.

Quadro 10 — Tarefas de Alan da Silva

Tarefa	Onde
Excluir as colunas de imagem da listagem e implantar paginação	app/api/anamneses/
Promover nome, cidade, data de emissão e data de nascimento a colunas próprias, com índice	prisma/schema.prisma e nova migration
Deixar de gravar a imagem do relatório; gerá-la sob demanda a partir do JSON	rota de gravação e tela de registros
Registrar autoria: vincular cada anamnese ao usuário que a criou	prisma/schema.prisma
Remover a pasta de compilação de 77 MB do repositório	dev/ e .gitignore

Fonte: elaborado pelo autor.

7.3 Lucas — Interface e qualidade

Responsável pelos defeitos visíveis ao usuário e pela dívida técnica acumulada.

Quadro 11 — Tarefas de Lucas

Tarefa	Onde
Validar o formulário antes do envio, conforme os campos obrigatórios definidos	components/anamnesis-form.jsx
Corrigir a tela de anamnese completa, que busca os dados no lugar errado	app/registros/[id]/page.jsx
Implementar a edição de anamnese já gravada	formulário e nova rota
Acionar o resumo e o download individual, hoje sem botão	app/registros/page.jsx
Remover a coluna "Sexo" da exportação ou acrescentar o campo ao formulário	app/metricas/page.jsx
Aplicar as listas fixas definidas pela orientação para cidade e motivo	formulário
Remover o código sem uso e comentar o arquivo central por seção clínica	vários

Fonte: elaborado pelo autor.

7.4 Professor Gustavo — Definição clínica

Nenhuma das tarefas abaixo pode ser resolvida pela equipe de desenvolvimento, pois dependem do protocolo do serviço e da leitura radiológica, área de formação do orientador. São, ao mesmo tempo, pré-requisito para parte do trabalho dos três desenvolvedores.

Quadro 12 — Tarefas do Professor Gustavo

Tarefa	Desbloqueia
Responder aos sete pontos do Quadro 6, em especial a condição da DUM e a distinção entre os dois desenhos esquemáticos	Lucas
Definir quais campos são obrigatórios para que a anamnese seja considerada válida	José Alan e Lucas
Revisar o vocabulário de alterações de pele e mamilo, à luz da terminologia radiológica adotada	Lucas
Definir se o parentesco deve registrar grau e idade ao diagnóstico, para estratificação de risco	Alan da Silva e Lucas
Definir as listas fixas de "motivo do exame" e "cidade"	Lucas
Validar o significado de cada campo descrito na seção 4, para incorporação à documentação	Equipe
Definir por quanto tempo os registros devem ser conservados e quem pode acessá-los	José Alan e Alan da Silva

Fonte: elaborado pelo autor.

Sugere-se que a seção 4 deste relatório seja revisada em conjunto com a orientação e, uma vez validada, incorporada à documentação do repositório como dicionário de dados oficial do projeto.

8 CONSIDERAÇÕES FINAIS

A plataforma cumpre o que se propôs: digitaliza um processo feito em papel, permite consultar e exportar o que foi registrado e produz indicadores agregados. A compilação de produção funciona, o procedimento de instalação da documentação foi executado com sucesso e as telas respondem como esperado. Não é pouco para um projeto estudantil.

Os problemas relatados situam-se em camada distinta daquela em que o trabalho foi concebido. Não dizem respeito ao que o sistema faz, e sim às condições sob as quais pode operar com segurança e crescer. É uma diferença comum em software que nasce como prova de conceito e é promovido a ferramenta de trabalho sem etapa intermediária de revisão — e é essa etapa que este relatório registra.

Chama-se a atenção, por fim, para o achado da seção 5.4, cujo alcance ultrapassa este projeto. A documentação afirmava que o controle de acesso funcionava, e essa afirmação bastava para encerrar o assunto aos olhos de quem a lesse. Documentação não é observação neutra sobre um sistema: ela orienta o que as pessoas vão ou não verificar. Quando descreve garantias de segurança, precisa ser tratada como afirmação a comprovar, não como descrição a aceitar.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6023**: informação e documentação: referências: elaboração. Rio de Janeiro: ABNT, 2018.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6024**: informação e documentação: numeração progressiva das seções de um documento: apresentação. Rio de Janeiro: ABNT, 2012.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 6028**: informação e documentação: resumo, resenha e resenha: apresentação. Rio de Janeiro: ABNT, 2021.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR 14724**: informação e documentação: trabalhos acadêmicos: apresentação. Rio de Janeiro: ABNT, 2011.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT. **OWASP Top 10:2021**: the ten most critical web application security risks. [S. l.]: OWASP Foundation, 2021.